

TASK 3

WEEK 3 – Windows Log Analysis & Threat Detection Report

Log Data Analysis Using Splunk

Table of Contents

Executive Summary	2
Full Attack Chain.....	2
MITRE ATT&CK Techniques Observed	3
Key Indicators of Compromise (IOCs)	3
Investigation Findings & Evidence	8

Executive Summary

A user opened a malicious Microsoft Word attachment delivered via Outlook that executed a macro and spawned PowerShell. The macro led to a staged payload (evil.exe) masquerading as svchost under the user profile, persistence via a Registry Run key, credential dumping (procdump / mimikatz), lateral movement via PSEXec, exfiltration activity using certutil, and ransomware encryption of almost 1500 files. Immediate containment is required.

Full Attack Chain

- *Initial Access (08:05:00)* - Spearphishing attachment received, user opened Word Document via Outlook.
- *Execution (08:05:08)* - Malicious word macro launched PowerShell (encoded command)
- *Payload Delivery and Persistence (08:05:14)* - PowerShell acted as an agent to download and execute a staged payload (**C:\Temp\evil.exe**), masqueraded as **svchost_*.exe** and written under the user profile to avoid detection. Persistence was created by adding a Registry Run key, modified to **REG_SZ C:\Temp\evil.exe - persist**, configured to execute on each logon.
- *C2 (08:05:16)* - svchost_*.exe established TLS connections to external hosts on TCP/443
- *Credential Access (09:35:00)* - **procdump.exe** and **mimikatz.exe** accessed **lsass.exe**
- *Lateral Movement (10:05:05)* - PsExec used to push payload to remote hosts (**SMB, port 445**)
- *Exfiltration (10:12:48) & Impact* - **certutil.exe** activity; **1500 files encrypted** (*.enc); **vssadmin.exe** used to delete shadow copies.

MITRE ATT&CK Techniques Observed

- **T1566.001** - Spearphishing attachment
- **T1059.001** - PowerShell (Command & Scripting Interpreter)
- **T1547.001** - Registry Run Keys (Persistence)
- **T1071.001** - C2 over HTTPS
- **T1003** - OS Credential Dumping
- **T1210** - Exploitation of Remote Services / PsExec
- **T1567** - Exfiltration over Web Service
- **T1486** - Data Encrypted for Impact

Key Indicators of Compromise (IOCs)

External IPs/hosts:

203.0. [REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]
[REDACTED]

Brute-Force source IPs (RDP):

- 45 [REDACTED]
- 185. [REDACTED]
- 103 [REDACTED]
- 91. [REDACTED] (Succeeded after 144 attempts)

Internal Hosts:

- **SOC-** [REDACTED] (the attack controller)
- **Lateral movement targets** (10.0. [REDACTED]
[REDACTED])

Files/paths /services:

- C:\[REDACTED]
- C:\[REDACTED]
- C:\[REDACTED]
- Registry [REDACTED]
- Services [REDACTED]

Processes Identified:

- OUTLOOK.EXE, WINWORD.EXE, POWERSHELL.EXE, procdump.exe, mimikatz.exe, certutil.exe, vssadmin.exe

Encrypted Files Identified:

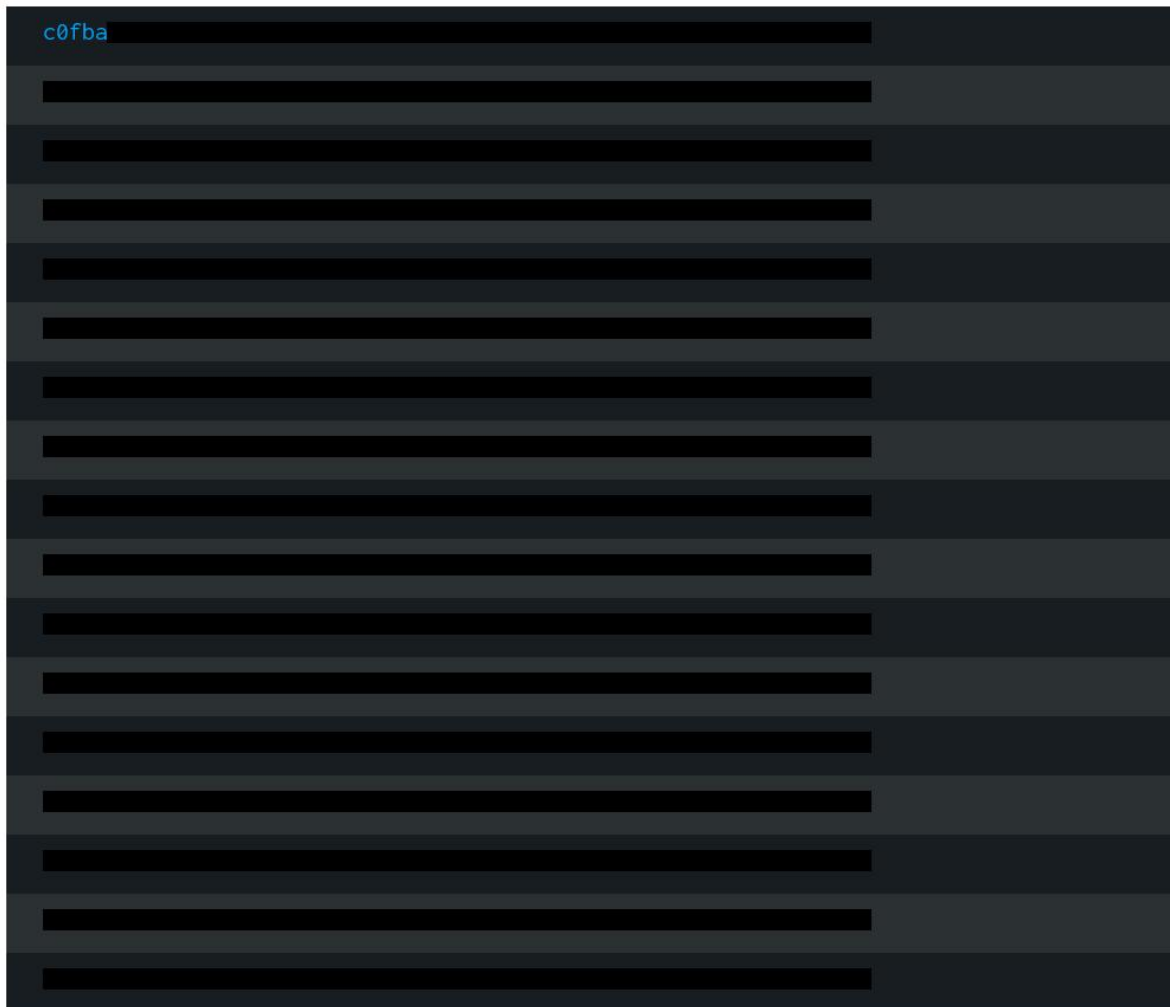
- C:\[REDACTED]
- ~1500 *.enc files

File Hashes:

[illegible]

22d7e

[REDACTED]

**Business Impact:**

- Approximately 1500 files were encrypted, which indicates potential data loss and impacts the operational environment. Since the shadow files were deleted by the attacker, local recovery is very unlikely.
- Lateral spread of the attack to multiple internal hosts indicates a broad infection potential. Critical services might be impacted due to this.
- LSASS dump indicates a high risk of stolen credentials; potential for persistent access and further privilege escalation
- The estimated urgency to address this issue is very high. This is an active ransomware with confirmed encryption and credential theft.

Recommended Containment and Remediation Actions:

➤ Immediate Actions

- Isolate infected machines from the network to stop the malware from spreading.
- Block suspicious IPs and network connections to prevent further communication with attackers.
- Disable affected user accounts and require password resets
- Collect basic evidence like logs and copies of suspicious files before making changes.

➤ Short-Term Actions

- Remove malware traces from affected systems, such as malicious programs.
- Update passwords and review user access for any compromised accounts.
- Patch and secure systems to prevent the same attack from repeating.
- Scan other devices for similar infections and clean them if needed.

➤ Long-Term Actions

- Enforce MFA for critical accounts
- Limit risky tools like PowerShell or unknown programs for normal users.
- Improve email security
- Conduct phishing awareness training for employees, so they can easily detect such attacks and report them immediately.
- Keep credentials safe and reduce admin privileges where possible
- Maintain secure backups and make sure they can be easily recovered when needed.

Investigation Findings & Evidence

[illegible]

```
source="master_soc_training.csv" host="Al's Laptop"
index="winevent_log" sourcetype="csv" |table time SubjectUserName
ParentProcessName ParentImage ParentProcessId Image NewProcessName
ProcessId CommandLine LogonId LogonType EventCode Protocol SourceIp
TargetUserName| sort 0 time
```

Used the above search query to create a timeline that would make it easier and more efficient to follow the logs and recreate the entire attack chain.

Task 1: Which process marked the beginning of the attack chain? Was it user initiated or a system process? Provide the process and its parent.

- Process marking beginning of the attack chain: **OUTLOOK.exe**.
- **User-initiated process** (initiated by **intern.user**, who unintentionally opened the malicious attachment sent by the threat actor)
- Parent Process: **OUTLOOK.exe**
- Child Process: C:\[REDACTED]

Task 2: Build the complete process tree from the initial process down to the malicious payload execution (Parent → Child → Grandchild). Include process names and command lines.

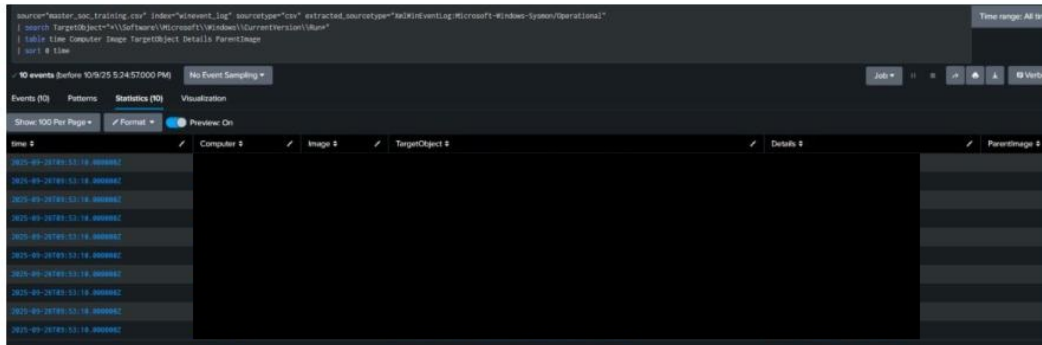
OUTLOOK.EXE (PID:7999); Command Line: WINWORD.EXE /q *[PARENT]*

Task 4: Find all processes that accessed lsass.exe. Which tool was used, and what access rights were requested?

```
source="master_soc_training.csv" index="winevent_log" sourcetype="csv"
extracted_sourcetype="XmlWinEventLog:Microsoft-Windows-
Sysmon/Operational" | table time Computer SourceImage SourceProcessId
TargetImage TargetProcessId GrantedAccess CallTrace | sort 0 time
```

- procdump.exe and mimikatz.exe were used to access lsass.exe.
- Both the tools mentioned above are credential dumping tools i.e, they are used to read LSASS memory to dump plaintext passwords and hashes.

Task 5: Was any scheduled task or registry run key created? Provide the task name, registry path, and associated executable.



```
source="master_soc_training.csv" index="winevent_log" sourcetype="csv"
extracted_sourcetype="XmlWinEventLog:Microsoft-Windows-
Sysmon/Operational" | search
TargetObject="\\Software\\Microsoft\\Windows\\CurrentVersion\\Run" | table
time Computer Image TargetObject Details ParentImage | sort 0 time
```

- The above query shows that a Registry Run Key, located at `\\Software\\Microsoft\\Windows\\CurrentVersion\\Run` was modified.
- The value `REG_SZ C:\\Temp\\evil.exe -persist` indicates that a malicious executable was configured to execute on each user login, which is a sign of persistent behaviour used by malware.
- There was no evidence of a scheduled task creation.

Task 6: Was a new service installed or modified (7045)? Provide ServiceName, ImagePath, and AccountName.

```
source="master_soc_training.csv" index="winevent_log" sourcetype="csv"
EventCode=7045 | table time Computer EventCode ServiceName ImagePath
AccountName | sort 0 time
```

Yes. From the logs, it has been observed that 2 new malicious services had been installed; along with the ImagePath and AccountName respectively:

1. MaliciousSvc --> C:\Temp\evil.exe -service - LocalSystem
2. PSEXESVC - -> C:\Windows\PSEXESVC.exe - LocalSystem

Task 7: Investigate whether the attacker moved laterally to other hosts (PsExec or remote services). List the remote hosts, service names, and network ports used.

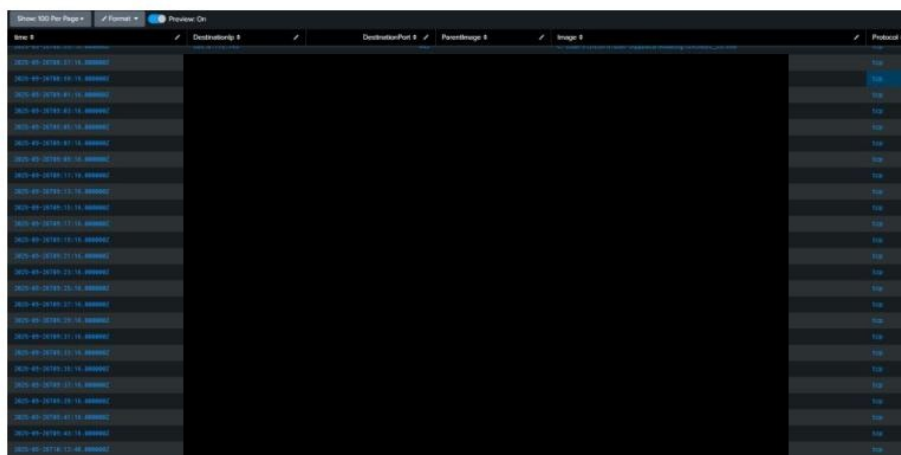
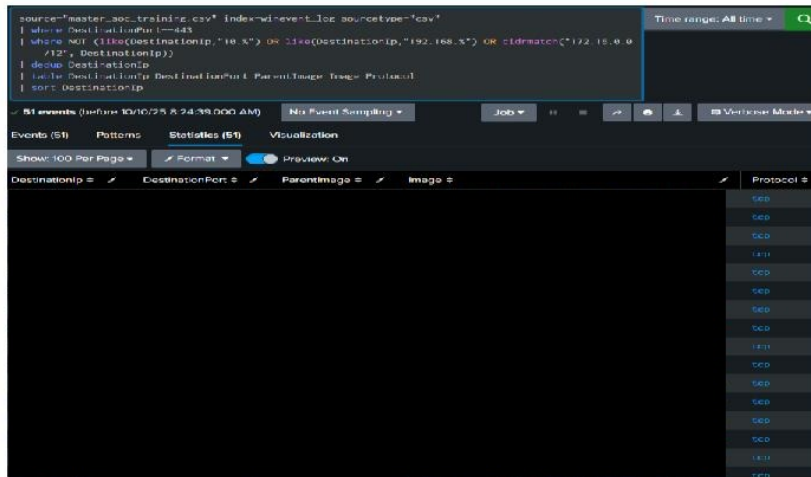
```
source="master_soc_training.csv" index="winevent_log" sourcetype="csv"
| eval RemoteHost=coalesce(TargetServerName, DestinationIp) | search
EventCode=7045 OR Image="psexec" OR CommandLine="psexec" OR
(Protocol="tcp" AND DestinationPort IN (135,139,445,3389,5985,5986)) |
table time Computer RemoteHost ServiceName ImagePath Image CommandLine
DestinationPort Protocol | sort 0 -time
```

time	Computer	RemoteHost	ServiceName	ImagePath	Image	CommandLine	DestinationPort	Protocol
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.2	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.2	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.3	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.3	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.4	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.4	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.5	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.5	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.6	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.6	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.7	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.7	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.8	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.8	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.9	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.9	445	TCP
2022-02-28T10:00:00.000Z	10.0.0.1	10.0.0.10	PSEXESVC	C:\Windows\PSEXESVC.exe	PSEXESVC.exe	psexec -u administrator -s 10.0.0.10	445	TCP

- Lateral movement via PsExec has been detected. The compromised source has a malicious payload 'evil.exe' running locally, which might have triggered the PSEXESVC.EXE to run, and make remote connections to the victim IPs, indicating that the host '10.0.0.1' is acting as the attack controller. The remote hosts 10.0.0.2, 10.0.0.3, 10.0.0.4, 10.0.0.5, 10.0.0.6, 10.0.0.7, 10.0.0.8, 10.0.0.9, and 10.0.0.10 have been targeted by the compromised source host 10.0.0.1, on port 445 (SMB) through the PSEXESVC.EXE, and the attacker has been able to perform lateral movement across the network.

Task 8: List all external IPs contacted over port 443. Which process established between these connections?

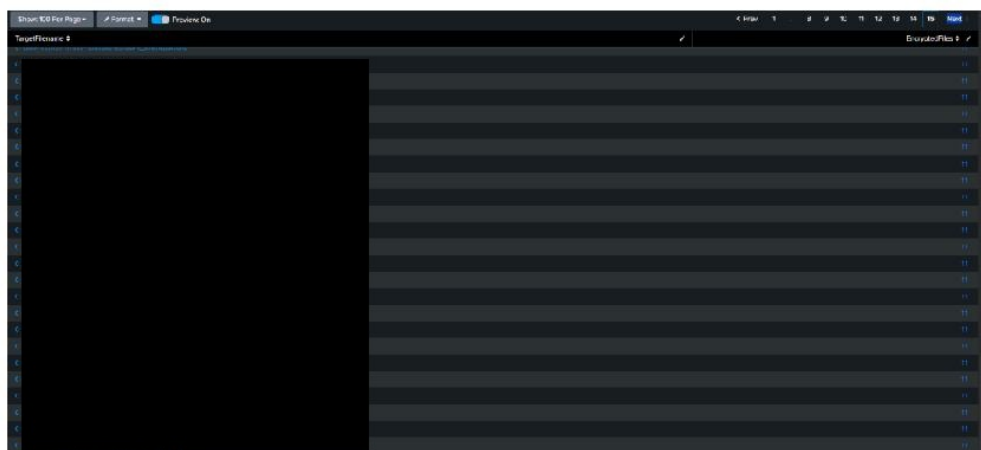
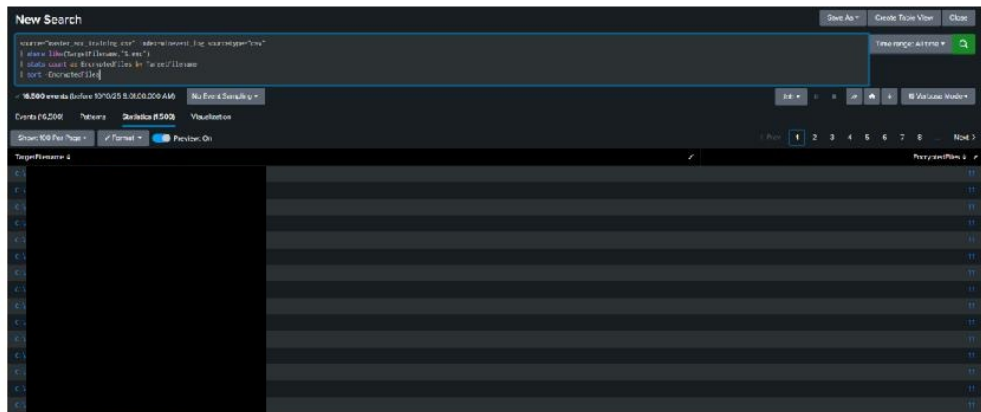

```
source="master_soc_training.csv" index=winevent_log sourcetype="csv" |
where DestinationPort==443 | where NOT (like(DestinationIp,"10.%") OR
like(DestinationIp,"192.168.%") OR cidrmatch("172.16.0.0/12",
DestinationIp)) | dedup DestinationIp | table time DestinationIp
DestinationPort ParentImage Image Protocol | sort DestinationIp| sort
0 time
```



- The external IP addresses contacted over port 443 are: 203.0. [REDACTED] and [REDACTED].
- Multiple svchost_* binaries (C:\[REDACTED]svchost_0.exe-C:\[REDACTED]svchost_49.exe), masquerading as legitimate svchost from a user profile have been observed. They have established outbound TLS connections to external hosts on TCP/443. These binaries are highly suspicious.

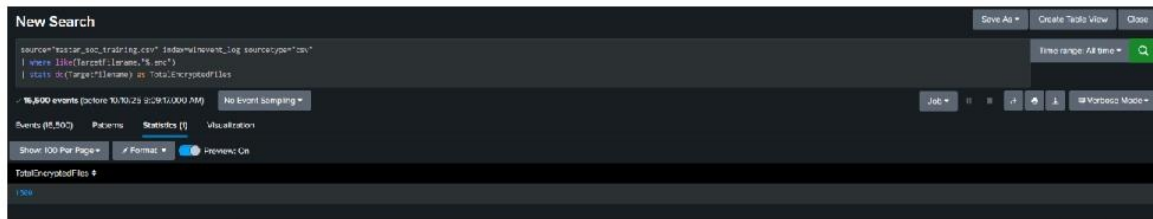
- It is also observed that **certutil.exe**, which is a legitimate tool, is commonly abused for file transfer/staging.

Task 9: How many files were encrypted (*.enc)? Did the attacker attempt to delete shadow copies using vssadmin.exe?



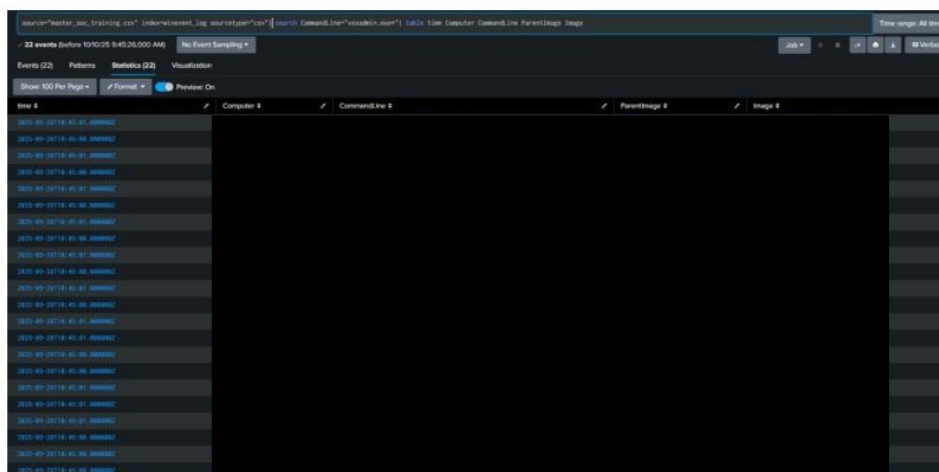
source="master_soc_training.csv" index=winevent_log sourcetype="csv" | where like(TargetFilename,"*.enc") | stats count as EncryptedFiles by TargetFilename | sort -EncryptedFiles | sort 0 time

- The query mentioned above was used to display the files that were encrypted, along with their unique counts.



`source="master_soc_training.csv" index=winevent_log sourcetype="csv" | where like(TargetFilename,"%enc") | stats dc(TargetFilename) as TotalEncryptedFiles`

- The query mentioned above gives us a distinct count (excluding the duplicate entries for the encrypted files). Hence, **1500 files** were encrypted by the attacker.



`source="master_soc_training.csv" index=winevent_log sourcetype="csv" | search CommandLine="vssadmin.exe" | table time Computer CommandLine ParentImage Image`

- The attacker attempted to delete all the shadow copies using vssadmin.exe. This means that the victim will not be able to recover any lost data and hence will be forced to pay the ransom amount if they want the data to be decrypted and given back to them.